

Admin access update

Safer admins and roles in the TOURISE 2027 admin. 5 October 2026.

1. In short

Until now, an admin who was allowed to **manage admins** could give themselves more power, all the way up to Super Admin, and could take over a Super Admin's account. That is now closed.

- **Nobody can raise themselves.**
- **Nobody can give more than they have.**
- **The Super Admin is out of reach of everyone else.**
- **Roles became a separate permission**, so a client can manage admins without being able to edit roles.

What you need to do: nothing for existing admins; nobody has to be deleted or re-created. After the update reaches production, a Super Admin ticks the new **Roles** boxes on the roles that should be able to edit roles.

Status (5 October 2026): on the development version for testing. It reaches production with the next release.

2. What was wrong

An admin whose role had only **Admins Management** (view, create, update) could do all of this:

#	What they could do	Why it mattered
1	See every Super Admin and the Super Admin role	They should not even know who they are
2	Create a new Super Admin with a password they chose	A hidden back door into the system
3	Reset the real Super Admin's password	Take over the most powerful account
4	Block a Super Admin (with the Block box)	Lock the owners out
5	Tick every permission on their own role	Become all-powerful without being Super Admin
6	Give themselves the Super Admin role	Promote themselves in one click
7	Add any admin, themselves included, to a category's "Admin access"	See guests outside their own area

#	What they could do	Why it mattered
8	Keep working for up to 6 hours after being blocked	Blocking was not immediate

We confirmed each of these on a test copy before fixing them, and each one now has an automatic test that fails if it ever comes back.

3. The new rules

1. **The Super Admin is out of reach.** Only a Super Admin can see, edit, block or assign Super Admins or the Super Admin role. For everyone else they are not in the lists, not in the role picker and not in the audit trails.
2. **You can only give what you have.**
 - In the role editor you only see, and can only tick, the permissions you hold yourself.
 - You can only give an admin a role that is not stronger than yours. The role picker shows only those.
 - You can only edit admins whose role is not stronger than yours.
 - The guest access you give (categories and statuses) cannot be wider than your own.
3. **Nobody raises themselves.** On your own record your role, guest access and status are locked. Your name, email and password stay editable. You cannot edit or delete the role you hold.
4. **Category "Admin access" follows the same rules.** It lists only admins you may manage, never yourself, and saving a category leaves the admins you cannot see untouched.
5. **Blocking is immediate.** A blocked admin is logged out on the spot.

Example. If all the permissions are 1, 2, 3, 4 and 5, and a client manager holds 1, 2 and 3, they can create admins with the roles 1-2-3, 1-2 or 1. They can never give a role with 4 or 5, and never the Super Admin role.

4. Roles is now its own permission

Before, one permission (Admins Management) covered both the Admins screen and the Roles screen. Now they are separate:

The person holds	Create admins	Create or edit roles
Admins Management only	Yes, with the roles that exist	No
Roles only	No	Yes, within their own permissions
Both	Yes	Yes

The new **Roles** boxes are View, Create, Update, Delete, Record History and Audit Trail. They **start unticked**: after the update, only Super Admins can open Roles until a Super Admin ticks Roles on a role.

5. What each person sees after the update

- **Super Admin:** everything, exactly as before.
- **An admin manager** (Admins Management): the admins and roles not stronger than theirs. No Super Admins, no Roles screen unless they also hold Roles.
- **A role editor** (Roles): the Roles screen, offering only the permissions they hold. No Edit or Delete on the role they hold themselves.
- **Everyone, on their own record:** role, guest access and status are greyed out, with a note that another admin can change them. No Block on their own row.

6. After the update: a short checklist for a Super Admin

1. **Tell the team** that the Roles screen is Super Admin only until the new boxes are ticked.
2. **Tick Roles** (View, Create, Update, Delete) on the roles that should edit roles.
3. **Check who holds the Super Admin role.** Before this fix anyone with Admins Management could have made one.
4. **Check roles with Admins Management or Roles**, and any role with suspiciously many permissions.
5. **Check that managers have the guest access they will hand out.** A manager can only give access they have themselves.

7. Questions and answers

Do we need to delete and re-create admins? No. Existing admins keep their roles, passwords and access. The rules apply when someone changes an admin or a role from now on.

Will anyone lose access? Only one thing: editing roles, for anyone who is not a Super Admin, until Roles is ticked on their role.

Why can't I change my own role or access? So that nobody can raise themselves. Another admin with the right permissions can change it for you.

Can two managers with the same role manage each other? Yes, for now: "the same" counts as "not stronger". Whether to allow it is still open.

Is any history lost? No. Changes to roles recorded before the split now show in the Roles audit trail.

8. For developers

- **The rule-book:** `app/Support/AdminHierarchy.php` (`isSuper` , `visibleAdmins` , `visibleRoles` , `roleWithin` , `mayManage` , `scopeWithin` , `grantsCategory` , `boxesBeyond`). Any new endpoint that creates or changes an admin, a role or an admin's guest access must ask it (ledger D55, AI_RULES must-do 8).
- **Applied in:** `AdminsController` (list, show, create, update, block, resend invite), `RolesController` (list, picker, catalogue, create, update, delete), `CategoriesController` (assignable admins, "assigned

admins" on create and update), `AuditLogsController` (Super Admin rows hidden from other viewers).

- **Roles split:** catalogue feature `roles` ; the Roles routes, catalogue and trails sit under it; `/admin/roles/select` (the admin form's picker) stays on `admins_management` .
- **Migration:** `2026_10_04_000002_move_role_audit_rows_to_the_roles_feature` refiles role audit rows from `admins_management` to `roles` . Only the `feature` column changes.
- **Tests:** `tests/Feature/AdminHierarchyTest.php` (11). The first 9 fail on the code before the fix. Backend 1051 tests pass.
- **Commits:** backend `379f74f` (PR #38), admin `91244e2` (PR #39), both on `dev` .
- **Deploy:** `php artisan migrate` , refresh cached routes, then tick Roles as in section 6.